МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ

Національний аерокосмічний університет
«Харківський авіаційний інститут»

факультет радіоелектроніки, комп'ютерних систем та інфокомунікацій

кафедра кібербезпеки та інтелектуальних інформаційних технологій

Лабораторна робота

з дисципліни «Сучасні методи проєктування програмного забезпечення»
(назва дисципліни)
за темою: Аудит безпеки веб-сайтів на базі CMS WORDPRESS
з використанням сканера вразливостей WPScan
(тема практичної роботи)

Харків – 2026

ЗМІСТ

1 МЕТА РОБОТИ 3
2 ЗАВДАННЯ РОБОТИ 3
3 КОРОТКІ ТЕОРЕТИЧНІ ВІДОМОСТІ 3
3.1 Актуальність захисту CMS WordPress 3
3.2 Призначення та архітектура інструменту WPScan 4
3.3 База даних уразливостей WPScan 4
4 ПРОГРАМА РОБОТИ 4
Крок 1. Підготовка середовища 4
Крок 2. Отримання API-токена 5
Крок 3. Оновлення бази даних уразливостей 5
Крок 4. Базове сканування 5
Крок 5. Енумерація вразливостей ядра 5
Крок 6. Енумерація плагінів 5
Крок 7. Енумерація тем 5
Крок 8. Енумерація зареєстрованих користувачів 5
Крок 9. Контрольована атака підбору паролів 5
Крок 10. Експорт результатів 6
5 ВИМОГИ ДО ЗВІТУ 6
6 КОНТРОЛЬНІ ЗАПИТАННЯ 6
7 СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ 7

1 МЕТА РОБОТИ

Метою лабораторної роботи є формування у здобувачів вищої освіти практичних навичок проведення чорнокоробкового (black-box) аудиту безпеки веб-сайтів, побудованих на системі керування контентом WordPress, шляхом використання спеціалізованого сканера вразливостей WPScan у середовищі операційної системи Kali Linux, а також формування вміння інтерпретувати результати сканування та формулювати обґрунтовані рекомендації щодо підвищення рівня захищеності досліджуваного ресурсу.

2 ЗАВДАННЯ РОБОТИ

У результаті виконання лабораторної роботи здобувач повинен:

1) ознайомитися з архітектурою CMS WordPress та типовими векторами атак на неї;
2) вивчити функціональні можливості сканера WPScan та його ключові параметри командного рядка;
3) отримати API-токен на сервісі wpscan.com і сконфігурувати підключення інструменту до бази даних вразливостей;
4) провести базове сканування тестового веб-сайту WordPress з метою визначення версії ядра та серверного оточення;
5) виконати енумерацію встановлених плагінів, тем та зареєстрованих користувачів з використанням пасивного та агресивного режимів;

3 КОРОТКІ ТЕОРЕТИЧНІ ВІДОМОСТІ

3.1 Актуальність захисту CMS WordPress

Система керування вмістом WordPress станом на 2025 рік використовується приблизно 43 % усіх веб-сайтів в Інтернеті та займає понад 60 % ринку CMS [1]. Саме через таку значну частку ринку WordPress залишається одним з найчастіше атакованих програмних рішень: щодоби фіксуються тисячі спроб експлуатації відомих уразливостей у ядрі, плагінах і темах.

Поверхня атаки типового WordPress-сайту охоплює декілька логічних рівнів: ядро (WordPress core), яке централізовано супроводжується офіційною командою проєкту; плагіни – компоненти розширення функціональності від сторонніх розробників, що, за даними WPScan, генерують близько 97 % усіх задокументованих уразливостей [2]; теми оформлення; облікові дані користувачів (передусім адміністраторів); а також сервіси периметру – інтерфейс XML-RPC, REST API, сторінка входу wp-login.php, які за замовчуванням залишаються доступними без додаткового обмеження.

3.2 Призначення та архітектура інструменту WPScan

WPScan – це спеціалізований сканер вразливостей з відкритим вихідним кодом, призначений для чорнокоробкового аналізу захищеності сайтів на базі WordPress. Інструмент розроблено Ryan Dewhurst у 2011 році; на теперішній час проєкт розвивається компанією Automattic (материнська компанія WordPress.com) [3]. У дистрибутиві Kali Linux інструмент присутній серед стандартних утиліт і запускається командою wpscan.

Основні функціональні можливості WPScan: визначення версії ядра WordPress методом fingerprinting (через аналіз meta-тегів HTML, файлу readme.html, специфічних рядків release-нотаток); енумерація встановлених плагінів у пасивному (через аналіз згенерованого HTML) та агресивному (через перебір відомих шляхів) режимах; енумерація тем оформлення; перелічення зареєстрованих користувачів за author-ID; звірка виявлених компонентів із базою WPScan Vulnerability Database; підбір паролів (brute-force) з використанням зовнішніх словників; виявлення типових помилок конфігурації (listing директорій, доступ до службових файлів) [4].

3.3 База даних уразливостей WPScan

WPScan використовує фірмову базу даних WPScan Vulnerability Database, яка станом на 2025 рік містить понад 55 тисяч задокументованих уразливостей ядра, плагінів і тем WordPress [5]. Починаючи з версії 3.x для доступу до бази необхідний API-токен, що його можна безкоштовно отримати після реєстрації на сайті https://wpscan.com. Безкоштовний план надає обмеження у 25 API-запитів на добу, що зазвичай достатньо для навчальних цілей та невеликих аудитів. Без API-токена WPScan виконує сканування, однак не повертає інформації про CVE-ідентифікатори та рівень критичності виявлених вразливостей.

4 ПРОГРАМА РОБОТИ

Робота виконується у середовищі Kali Linux. Як тестовий об’єкт рекомендовано використовувати локально розгорнутий екземпляр WordPress (Docker-контейнер з офіційного образу, віртуальна машина з Bitnami WordPress, DVWA-WP) або спеціально призначені для цього навчальні ресурси.

Крок 1. Підготовка середовища

1.1 Запустити віртуальну машину Kali Linux і відкрити термінал.

1.2 Оновити індекси пакетів та встановлені пакети:

```
sudo apt update && sudo apt upgrade -y
```

1.3 Перевірити наявність WPScan і його версію:

```
wpscan --version
```

Якщо інструмент відсутній, встановити його з офіційного репозиторію:

```
sudo apt install wpscan -y
```

Крок 2. Отримання API-токена

2.1 Зареєструвати безкоштовний обліковий запис на https://wpscan.com.

2.2 У розділі «Profile» скопіювати значення API-Token.

2.3 Зберегти токен у змінну середовища поточного сеансу:

```
export WPSCAN_TOKEN="YOUR_TOKEN_HERE"
```

Крок 3. Оновлення бази даних уразливостей

```
wpscan --update
```

Крок 4. Базове сканування

```
wpscan --url http://target.local --api-token $WPSCAN_TOKEN
```

Зафіксувати у звіті: версію ядра WordPress, назву та версію веб-сервера, наявність відкритих директорій, виявлені інтерфейси (XML-RPC, REST API, wp-cron).

Крок 5. Енумерація вразливостей ядра

```
wpscan --url http://target.local --enumerate vp --api-token $WPSCAN_TOKEN
```

Крок 6. Енумерація плагінів

Пасивний режим (швидший, менш інвазивний):

```
wpscan --url http://target.local --enumerate ap --plugins-detection passive --api-token $WPSCAN_TOKEN
```

Агресивний режим (точніший, але повільніший, створює значно більше запитів до сервера):

```
wpscan --url http://target.local --enumerate ap --plugins-detection aggressive --api-token $WPSCAN_TOKEN
```

Крок 7. Енумерація тем

```
wpscan --url http://target.local --enumerate at --api-token $WPSCAN_TOKEN
```

Крок 8. Енумерація зареєстрованих користувачів

```
wpscan --url http://target.local --enumerate u --api-token $WPSCAN_TOKEN
```

У звіті навести отриманий перелік імен користувачів і пояснити, через які особливості WordPress (author archive, REST API /wp-json/wp/v2/users) стала можливою їхня енумерація.

Крок 9. Контрольована атака підбору паролів

Попередньо сформувати скорочений словник (перші 100 записів rockyou.txt), щоб уникнути перевантаження тестового сервера:

```
head -100 /usr/share/wordlists/rockyou.txt > ~/short.txt
```

Запустити атаку з обмеженою кількістю потоків:

```
wpscan --url http://target.local --usernames admin \ --passwords ~/short.txt --max-threads 5
```

Крок 10. Експорт результатів

У текстовому форматі без ANSI-кольорів:

```
wpscan --url http://target.local --api-token $WPSCAN_TOKEN \
-o report.txt -f cli-no-color
```

У форматі JSON – для подальшої автоматизованої обробки:

```
wpscan --url http://target.local --api-token $WPSCAN_TOKEN \
-o report.json -f json
```

5 ВИМОГИ ДО ЗВІТУ

Звіт оформлюється відповідно до вимог ДСТУ 3008:2015 та має містити титульний лист з відповідними реквізитами, зміст, мету та завдання роботи, хід роботи з чіткою послідовністю дій та висновки.

6 КОНТРОЛЬНІ ЗАПИТАННЯ

1. Що таке CMS WordPress та якою є її поточна частка на ринку систем керування вмістом?
2. Які компоненти WordPress становлять найбільшу поверхню атаки і чому?
3. У чому різниця між пасивним і агресивним режимами енумерації плагінів у WPScan?
4. Які методи fingerprinting використовує WPScan для визначення версії ядра WordPress?
5. Яка команда використовується для оновлення локальної бази даних уразливостей WPScan?
6. Як WPScan виконує енумерацію користувачів та які особливості WordPress роблять її можливою?
7. Чим WPScan відрізняється від сканерів загального призначення (Nikto, OWASP ZAP, Nuclei)?
8. Які параметри WPScan дозволяють регулювати інтенсивність запитів до тестового сервера?

7 СПИСОК ВИКОРИСТАНИХ ДЖЕРЕЛ

1. W3Techs. Usage statistics of content management systems [Електронний ресурс] // W3Techs. 2025. URL: https://w3techs.com/technologies/overview/content_management (дата звернення: 12.04.2026).

2. WPScan. Vulnerability statistics [Електронний ресурс] // WPScan. 2024. URL: https://wpscan.com/statistics/ (дата звернення: 12.04.2026).

3. Dewhurst R. WPScan: WordPress security scanner. GitHub repository [Електронний ресурс]. 2011–2025. URL: https://github.com/wpscanteam/wpscan (дата звернення: 12.04.2026).

4. WPScan. Official documentation [Електронний ресурс] // WPScan. 2025. URL: https://wpscan.com/documentation (дата звернення: 12.04.2026).

5. WPScan Vulnerability Database [Електронний ресурс] // Automattic. 2025. URL: https://wpscan.com/wordpress-vulnerabilities (дата звернення: 12.04.2026).

6. OWASP Top 10:2021. The ten most critical web application security risks [Електронний ресурс] // OWASP Foundation. 2021. URL: https://owasp.org/Top10/ (дата звернення: 14.04.2026).

7. Common Vulnerability Scoring System version 3.1: Specification Document [Електронний ресурс] // FIRST. 2019. URL: https://www.first.org/cvss/v3.1/specification-document (дата звернення: 14.04.2026).

8. Kali Linux Tools: WPScan [Електронний ресурс] // Offensive Security. 2025. URL: https://www.kali.org/tools/wpscan/ (дата звернення: 14.04.2026).